RansomWhale Unleashed: An Immersive Learning Experience in Ransomware Operations

Liran Ma and Taylor Griffin
Department of Computer Science
Texas Christian University

Introduction

Ransomware poses an **ongoing** and **ever-evolving threat to computer security**, jeopardizing the integrity of data and rendering files and systems absolutely useless. These attacks involve the utilization of malicious software to **encrypt** victim data, effectively holding it hostage and **demanding a ransom** in exchange for decrypting the files and restoring access to their crucial contents. As a result, individuals and organizations face a relentless battle to safeguard their information and mitigate the severe consequences of these relentless cybercrimes.

Shockingly, ransomware attacks have surged in recent years, affecting 37% of businesses and organizations in 2021 and resulting in a staggering cost of $20 billion worldwide. It is estimated that by 2031, this amount will skyrocket to $265 billion. (cloudwards.net)

This lab aims to provide an educational environment where participants can gain a comprehensive understanding of the **structure and processes underlying ransomware attacks**. Through hands-on exploration, we will delve into the intricate details of **infection, encryption, remuneration, and decryption** associated with ransomware incidents, as well as how to **implement preventive measures** and **respond to an attack**.

To ensure a **controlled and safe learning experience**, we will leverage the power of **Docker containers** and utilize **RansomWhale**, a ransomware program that specifically targets files within a user's home directory, encrypting them as an illustrative example.

Contents

1 Ransomware Infection **2**
1.1 Lab Prep (Docker) 2
1.2 Infection 3

2 File Encryption **3**
2.1 Exploring the Victim's files 4
2.2 Exploring the Attacker's files 4
2.3 Getting RansomWhale'd 5

3 Remuneration and Decryption **5**
3.1 Ransomware Aftermath . . . 5
3.2 Payment . . . 6
3.3 Key Exchange . . . 6
3.4 File Decryption . . . 7

4 Prevention **7**
4.1 Creating Backups . . . 7
4.2 Using Caution with Emails . . . 9
4.3 File Scanning before execution . . . 10
4.4 Staying Updated . . . 11

5 Mitigation **12**
5.1 Isolating the System . . . 12
5.2 Reporting the Threat . . . 12

6 Sources and Additional Reading **13**

7 Troubleshooting **13**

8 General Questions **14**

1 Ransomware Infection

A ransomware campaign can be launched by an attacker using various techniques, including phishing, social engineering, spam, and advertisements. One popular method employed by attackers involves sending phishing emails with malicious links and attachments, making it difficult for victims to detect the threat. In this section, we will see an example of a phishing email that directs users to a deceptive website, aiming to trick them into downloading malicious software.

1.1 Lab Prep (Docker)

Go to your local GitHub folder and pull the files using the git command below.

```
git clone https://github.com/imtaylorgriffin/RansomWhale.git
# Use ‘‘git pull’’ if you have cloned the project before
```

Next, have two separate terminal windows open and start the container instances:

```
cd to the newly created RansomWhale folder

docker-compose up -d
# Starts all containers, make sure you’re in the Ransomwhale folder

# or docker-compose up -d --build --remove-orphans --force-recreate
# If you’re restarting the Lab.

docker container exec -it victim /bin/sh
# Victim terminal - open in terminal window 1
```

```
docker container exec -it attacker /bin/sh
# Attacker terminal - open in terminal window 2
```

1.2 Infection

We will utilize Docker to look at how one may get infected with Ransomware. In your victim terminal:

```
cd ~/email/
# this is where your Inbox and Sent emails will show up.

cd inbox/
# check the files with ls.
```

It looks like you have a new email!. Go ahead and *cat* the email file and follow the directions.

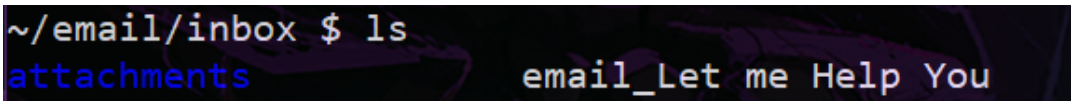


Figure 1: Victim's Email Inbox

After following the directions, you should be greeted by the HomeworkHeroes website. This is our attacker's website, it is important to note that attackers often employ various techniques to make their websites appear legitimate and trustworthy, aiming to deceive users into downloading their malicious software.

A common tactic used by attackers is to mimic the design and layout of legitimate websites, creating a false sense of familiarity and authenticity. They may use similar logos, color schemes, and content to make their websites visually appealing and convincing. Also, they may use persuasive language and compelling stories to entice users into taking specific actions, such as downloading a file or providing personal information.

```
Click the Download button.
# It is very important you do not open the application yet!
# Move the downloaded HomeworkHeroes.py to Ransomware/victim/Downloads
```

2 File Encryption

Following the execution of this Ransomware, it begins encrypting all of the victim's non-boot dependent files, in our case it's the sample texts in the home folder.

Generally after encryption, a pop-up window appears telling you that your files have been encrypted, along with payment procedures to follow if you want to restore them. When you try to open an encrypted file, it will fail to operate normally, and examining it in a text editor will show the contents as a jumbled up output of characters. This is because Ransomware encrypts the file's bytes, resulting in strange-looking content and the inability to run the file normally.

It is also a popular practice to change the extension of the encrypted files, an example would be .locked, .encrypted, and .locky, to name a few.

2.1 Exploring the Victim's files

If you haven't already, go into your Victim and Attacker terminals with:

```
docker container exec -it victim /bin/sh
# Victim terminal

docker container exec -it attacker /bin/sh
# Attacker terminal
```

In the Victim terminal:

```
cd ~
# Go to your home folder

ls

# cat the sample text files so you can see what they look like.
```

2.1.1 (Optional): You can create a file with *vi example.txt* and type whatever you'd like.

2.2 Exploring the Attacker's files

Go into your Attacker's terminal, if you *ls* you should see the email directory and a private_key.pem file.

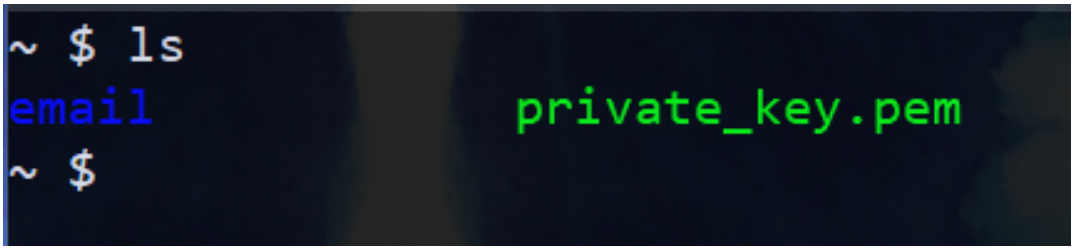


Figure 2: Attacker Directory

RansomWhale uses a **hybrid encryption scheme**, which combines the advantages of both symmetric encryption and asymmetric encryption. In asymmetric encryption, each user has a pair of keys: a public key that can be shared with anyone, and a private key that must be kept secret. In symmetric encryption, the same key is used to encrypt and decrypt data. To encrypt the files on a victims computer, RansomWhale does the following:

```
It generates a symmetric key to encrypt all of their files in the victim's home
directory with AES.

It encrypts the symmetric key with the attackers public key, which is embedded
```

```
in the ransomware code. Only the attacker has the corresponding private key,
which is needed to decrypt the symmetric key.

It deletes the original files, leaving only the encrypted files and the encryp-
ted symmetric key on the victims computer.
```

To decrypt the files, the victim has to pay the ransom and obtain the attackers private key. Then, they can use it to decrypt the symmetric key, and use the symmetric key to decrypt their files.

2.3 Getting RansomWhale'd

When you're ready, on your Victim terminal:

```
cd ~/Downloads

python HomeworkHeroes.py
# Start RansomWhale!
```

2.3.1 Take a screenshot of your Victim's terminal

If successful, all of the Victim's home folder files should be encrypted.

3 Remuneration and Decryption

Oh no! All of your important files have been encrypted! What do you do? After file encryption, the average user may have no idea how to resolve their issue. The attacker expects you to pay the ransom in order for them to restore your files.

RansomWhale is designed to both encrypt and decrypt files, however it can only decrypt files with it's symmetric key, which was encrypted, so it needs the attacker's Private Key in order to decrypt the symmetric key, which will in turn decrypt the victim's files. So, after paying the ransom, the attacker will send the necessary key to the victim, and all the victim has to do is place it in the same folder.

In this section, we are going to simulate payment of the attacker and the decryption of the victim's files.

3.1 Ransomware Aftermath

View the changes in your home folder by going on your Victim's terminal, *cd ~* to go back to your home folder and *ls*.

3.1.1 Take a screenshot of your Victim's home folder files.

cat a few of the files to view their outputs.

3.1.2 What do you notice about the outputs of the files?

3.1.3 (Optional) *cp* a sampleFile over to your Downloads directory and try to open it outside of docker (RansomWhale/victim/Downloads) and describe your result.

3.2 Payment

To simulate the payment of the ransom, on the Victim's terminal:

```
cd ~/email/

ls
# You should see both a pay.sh and send.sh script:
```

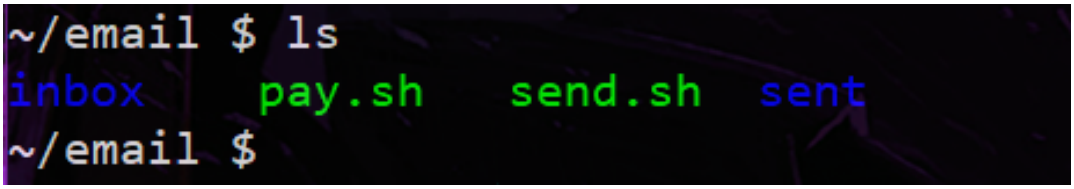


Figure 3: Victim's Inbox

If needed, reread the ransom note using *cat ~/Downloads/ransom.note*

To start the payment script:

```
sh pay.sh | tee -a email_payment
# It should ask you to input the value.
# This command runs the payment script and saves the output to email_payment

sh send.sh
# To send your email!
```

3.2.1 Is paying the ransom a good idea? Why might an organization pay the ransom?

3.2.2 Is it possible to avoid paying the ransom? How else might you solve this issue?

3.3 Key Exchange

After receiving payment, it is the Attacker's turn to respond. Switch over to your Attacker's terminal

```
cd email/inbox/

ls
# Check for new emails!
# If the victim's email successfully went through, it should show up.

cat email_payment
# To read it.
```

After reading the receipt, you should email the private key over:

```
mv ~/private_key.pem ~/email/

sh send.sh

ls ~/email/sent/attachments/
# To verify if the email was successfully sent.
```

3.4 File Decryption

Finally, we are now able to restore our files back to normal, all we have to do is grab the key.

In the Victim's terminal:

```
ls ~/email/inbox/attachments
# You should see the private_key.pem file!

mv ~/email/inbox/attachments/private_key.pem ~/Downloads/
# To place it in the same folder as RansomWhale

cd ~/Downloads.
```

To start the decryption process, make sure you have have both keys in the same directory with HomeworkHeroes.py, then use *python HomeworkHeroes.py*

3.4.1 Take a screenshot of the output

Lastly, *cd* ~ to go to your home directory and view the files. *cat* a few of the files, and if successful, they should all have their original data!

4 Prevention

By participating in the lab so far, it's easy to imagine how much damage ransomware can affect businesses and people globally.

Now that we know how a ransomware attack works, lets look at how to prevent it.

4.1 Creating Backups

Creating backups is crucial, not just for security purposes, but also in the event your data gets corrupted through normal usage. With a backup, you can always restore back to a working point.

To begin with this part of the lab, we need to reset our environment, in the victim's terminal:

```
rm -r ~/Downloads/*
# Deletes everything in the Downloads directory

exit
# Exit the terminal
```

```
docker-compose up -d --build --remove-orphans --force-recreate
# Resets the container

docker container exec -it victim /bin/sh
# Victim terminal
```

In the Victim terminal:

```
cd Apps/

ls
# You should now see a python application named backup.py
```

```
for file in os.listdir(home_dir):
    file_path=os.path.join(home_dir, file)
    if os.path.isfile(file_path):
        shutil.copy2(file_path,backup_dir)
        print(f'{file_path} {"restored" if args.restore else "backed up to"} {backup_dir}')
```

Figure 4: Backup Program Code

This is a simple application that will backup our sampleText files from our home directory, to start it, type *python backup.py* and observe the output.

4.1.1 Where did the files backup to? cd to the given directory. Are they there? cat the files to view the outputs.

4.1.2 What is the significance of the /mnt directory? In terms of file backups, is it more advantageous to store them directly on the system or save them to a different location?

Now that we've backed up our important files, lets see how we can prevent ransomware damages.

Continue from Section 1.2 to 2.3 so that all of your victim's home directory files are encrypted like so:

```
~ $ ls
1sampleText.txt.RansomWhale.mp4  Apps
2sampleText.txt.RansomWhale.mp4  Downloads
3sampleText.txt.RansomWhale.mp4  email
```

Figure 5: Victims Encrypted Files

Paying the ransom to retrieve their files was the choice made by our victim in the last scenario. **This approach is not recommended** as it not only fuels the motivation behind this criminal behavior, but it also frequently fails to result in complete decryption of files. Even if decryption does occur, it is highly unlikely that all files will be fully recovered.

Fortunately, since our victim implemented a backup process this time, they no longer need to concern themselves with the trouble of paying the ransom or facing the loss of their files.

To simulate the restoration of the victim's files:

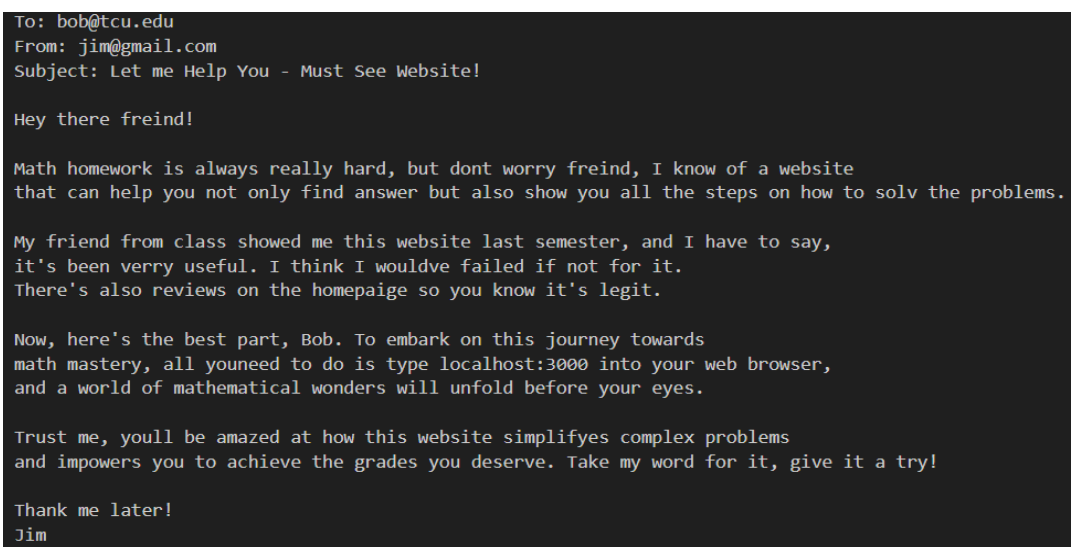
```
cd ~/Apps

python backup.py -r
# "Restores" our files from the backup drive

cd ~ && rm ~/*RansomWhale*
# Deletes our old encrypted files

ls
# We now have our old files back!
```

4.2 Using Caution with Emails

One of the most effective methods to **safeguard** against a wide range of malware, including ransomware, is by exercising **caution** when dealing **with emails**. It is essential to acknowledge that **users frequently act as the weakest link in maintaining a secure system**.

Cybercriminals employ various strategies, often capitalizing on the innate human tendencies and the kind nature of people in order to install malicious software on systems. Exploiting users through **email-based attacks** remains a **preferred and relatively effortless approach** for cybercriminals.

Lets examine the email from Section 1.2 again:



```
To: bob@tcu.edu
From: jim@gmail.com
Subject: Let me Help You - Must See Website!

Hey there freind!

Math homework is always really hard, but dont worry freind, I know of a website
that can help you not only find answer but also show you all the steps on how to solv the problems.

My friend from class showed me this website last semester, and I have to say,
it's been verry useful. I think I wouldve failed if not for it.
There's also reviews on the homepaige so you know it's legit.

Now, here's the best part, Bob. To embark on this journey towards
math mastery, all youneed to do is type localhost:3000 into your web browser,
and a world of mathematical wonders will unfold before your eyes.

Trust me, youll be amazed at how this website simplifyes complex problems
and impowers you to achieve the grades you deserve. Take my word for it, give it a try!

Thank me later!
Jim
```

Figure 6: Phishing Email

On the surface, the email looks innocent, however, a common technique attackers use is **Social Engineering**. Within this technique, attackers use **psychological manipulation** in order to

gain the user's trust and persuade them to download the attacker's malware. Attackers make these emails to appear as genuine and trustworthy, and may impersonate respected organizations, friends, family, or colleagues.

A creative way to identify these malicious emails is by using **S.O.U.P**, with this technique we analyze:

```
S: Suspicious sender
# Where does the email originate from? Do you recognize it?
# Is it within or outside of your organization?

O: Odd request
# What does the sender want from you?
# Are they asking for information or linking you to another website?

U: Unsafe action
# What is the sender asking you to do?
# Is the sender prompting you to download or click an attachment?

P: Poor Writing
# Does the sender use correct grammar?
# Is their email readable?
```

If the email in question raises any red flags going through the list, then it likely was sent with malicious intentions.

4.2.1 Read through the email and use the S.O.U.P technique to identify what makes this email suspicious.

4.2.2 (Optional): Have you recently received an email that made you suspicious after reading it? Analyze it with this technique and note your findings.

4.3 File Scanning before execution

Let's say the attacker persuaded you to download their application. What should you do if you download a file and are unsure of its legitimacy? The good thing is your operating system most likely provides an initial layer of protection with it's native antivirus software, Windows Defender for Windows and XProtect for macOS, which will help quarantine threats it immediately detects, however, it may not always have the most up to date threat information.

To enhance your security, consider using an additional trusted online scanning service like VirusTotal. With VirusTotal you can upload the questionable files for security analysis by multiple security vendors and their various antivirus engines. By using their collective evaluations, you gain an overview of potential security risks the file has, helping you make a more informed decision.

To check the legitimacy of a file you can head to **www.virustotal.com/gui/home/upload** where you can upload it and have it run through VirusTotal's security vendors.

VirusTotal also provides the option of scanning links as well, which can give you a better overall picture of the potential risks of executing the file.

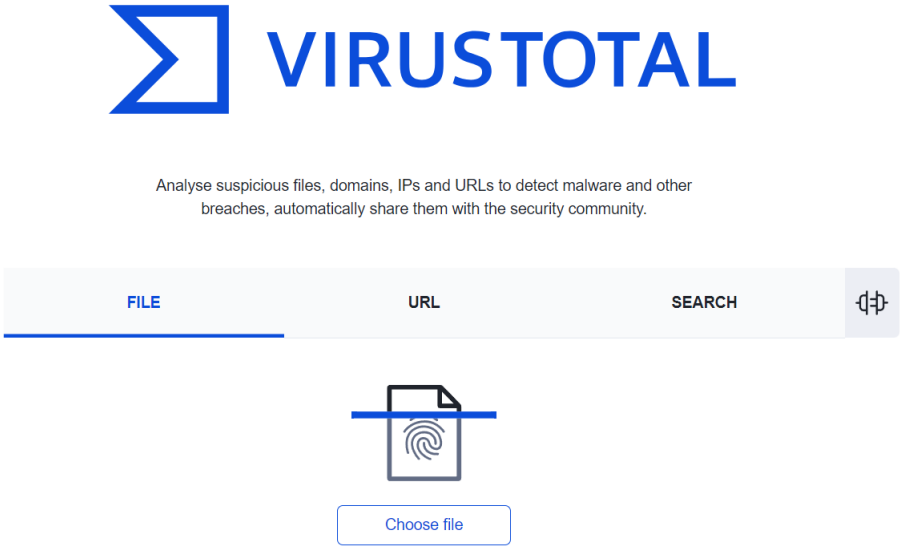


Figure 7: VirusTotal Homepage

4.3.1 (Optional): Have you downloaded any files or visited any websites that you thought were suspicious? Put them into VirusTotal and see if any of the vendors have flagged them.

It should also be mentioned that file scanning should not be the only determining factor on if you should open a questionable file as these resources are not immediately up to date with the newest emerging malicious software, and as a result, scanning new malware like RansomWhale will produce a safe result.

4.4 Staying Updated

Maintaining a strong defense against cyber-threats requires keeping your computer up to date. By regularly updating your computer, you will patch old vulnerabilities, increasing the efficacy of your anti-virus protection.

For example, on May 12th, 2017, the infamous ransomware WannaCry struck; this ransomware attack affected over 200,000 systems in over 150 different countries; however, what made these specific computers vulnerable was their usage of older, unpatched versions of Windows. In fact, data from Kasperkey labs shows that an enormous 98% of victims were using Windows 7, with Windows XP trailing behind. Had the victims updated to the newest available version, they would have never been affected.

To ensure that your computer is up to date, you can follow these guidelines:

```
Enable Automatic updates
# Enable automatic updates in your operating system to regularly check and
  install the latest security patches and bug fixes.
```

```
Update Software applications
# Many applications also provide automatic updates, but you can also inst-
  all them manually

Stay informed on cyber-threats
# These will notify you of any critical updates or patches that need to
  be installed. Good sources include:
  https://www.cisa.gov/   https://attack.mitre.org/
```

4.4.1 Using everything you've learned so far about Prevention, design a plan on how you would prevent a ransomware attack.

5 Mitigation

Unfortunately, if you haven't implemented any of the above prevention practices, and you have been infected with ransomware, there's not too much you can do to restore your files back to their working condition. You could still try to boot into a recovery mode and check if you do actually have a backup to restore from, but depending how far back it was performed, you may risk losing your newest files. However, even if your files are toast, there are still some mitigation strategies you can use to minimize the impact and reduce the potential for future attacks.

5.1 Isolating the System

When dealing with a ransomware attack, one of the first things you should do is disconnect the infected system from the network. By doing so, you take away the ability for the ransomware to spread through the network and infect other connected devices or encrypt shared storage.

5.2 Reporting the Threat

Reporting the ransomware incident plays a crucial role in curbing the spread of the malware and protecting others from falling victim to it. By reporting the situation, organizations can gather vital information, take swift action, and contribute to the investigation. This proactive approach aids in identifying patterns, gauging the rate of propagation, and finding the identities of the attackers.

In the event of a ransomware infection on your organization's computer, promptly contact the IT department to ensure prompt response and mitigation measures. However, if your personal computer has been compromised, it is advisable to report the incident to law enforcement authorities such as the FBI, CISA, or the U.S. Secret Service, at the following links:

```
https://www.cisa.gov/forms/report

https://ransomware.ic3.gov/default
```

Furthermore, platforms like VirusTotal provide a community tab where users can engage in discussions and collectively assess the legitimacy and threat level of files. This collaborative approach helps in better understanding the nature of the file and aids in determining whether it poses a risk.

When reporting a ransomware attack, it is beneficial to have the following essential information readily available:

```
Incident Details
# Description of the incident
# Ransomware variant (if known)
# Indicators of Compromise: file extensions (Figure: 5), emails (Figure: 6),
  URLs, etc
# Timeline of events

Impact
# Data or Files Encrypted
# Extent of Damage: Describe the impact on the system and what data was lost

Actions Taken
# Isolation: How did you isolate the system from the network?
# Reporting: Did you notify anyone?
# Mitigation: Did you do anything to minimize the spread?
```

5.2.1 (Optional): Design an Incident Report given the above template.

6 Sources and Additional Reading

www.cloudwards.net/ransomware-statistics

www.cisa.gov/stopransomware

www.sans.org/blog/recommended-sources-for-ransomware-information/

www.frontiersin.org/articles/10.3389/fcomp.2021.563060/full

www.theverge.com/2017/5/19/15665488/wannacry-windows-7-version-xp-patched-victim-statistics

www.cnet.com/tech/computing/wannacry-ransomware-how-to-protect-your-pc/

7 Troubleshooting

7.0.1 Want to reset the containers and redo?

Make sure you are in the RansomWhale folder:

```
docker-compose up -d --build --remove-orphans --force-recreate
# Forcefully recreates everything
```

7.0.2 Not able to start the containers?

Make sure you are inside the cloned RansomWhale folder and then use:

```
docker-compose up -d
# Starts all the containers
```

8 General Questions

8.0.1 Any corrections or general comments about this lab?

8.0.2 How long did it take you to complete this lab?

8.0.3 Was it an appropriate length lab?